

CVE-2026-40361

Microsoft Word Remote Code Execution Vulnerability

Threat Intelligence Report | Published: May 13, 2026

Attribute	Detail
CVE ID	CVE-2026-40361
Disclosure Date	May 12, 2026 (Microsoft Patch Tuesday)
Vulnerability Type	Use-After-Free → Remote Code Execution (RCE)
Affected Component	Microsoft Word (shared DLL also used by Outlook)
CVSSv3 Score	8.4 — Critical
Attack Vector	Local / Preview Pane (no user interaction beyond folder browse)
Authentication	None required
Privileges Required	None
Exploit Status	Exploitation More Likely (Microsoft assessment)
Zero-Day	No — patched same day as disclosure
Patch Available	Yes — KB update via Microsoft May 2026 Patch Tuesday



AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Query Disclaimer: All detection queries (Sigma, KQL, YARA, SPL) included in this report are generic templates. They are designed as a starting point and will likely require adaptation to match your organisation's specific environment, data sources, field names, log formats, and SIEM/EDR platform configuration.

Currency: Information in this report is based on publicly available sources at the time of generation. Threat intelligence evolves rapidly — verify all details against the latest vendor advisories, MSRC, NVD, and CISA guidance before relying on this document.

1. Executive Summary

CVE-2026-40361 is a critical Remote Code Execution (RCE) vulnerability in Microsoft Word, disclosed and patched on May 12, 2026 as part of Microsoft's monthly Patch Tuesday update cycle. The flaw stems from a use-after-free (UAF) memory corruption condition in a DLL shared between Word and Outlook. Critically, exploitation does not require a user to open the malicious document — merely previewing it in the Windows Explorer Preview Pane is sufficient to trigger code execution in the context of the logged-in user.

Microsoft assessed this vulnerability as 'Exploitation More Likely,' placing it alongside CVE-2026-40364 as the two highest-priority Word CVEs in the May 2026 release. Because the vulnerable DLL is also loaded by Outlook, enterprise email environments face compound risk — an attacker delivering a malicious .docx attachment via phishing could silently trigger execution when a recipient simply navigates to their Downloads folder with the Preview Pane active.

Organizations should apply the May 2026 Patch Tuesday updates immediately. Where patching cannot be completed at once, disabling the Preview Pane and Reading Pane via Group Policy is the recommended interim control.

2. Vulnerability Details

2.1 Root Cause

The vulnerability is a use-after-free (UAF) bug — a class of memory safety flaw where a program continues to use a pointer to memory after that memory has been freed. In Microsoft Word, a specific code path triggered during document rendering frees an object but retains a dangling reference. When that reference is subsequently dereferenced, an attacker who controls the document content can influence the heap state to redirect execution to attacker-supplied code.

The affected code path resides in a shared DLL loaded by both Word and Outlook. This means the attack surface is broader than a Word-only flaw: any process that loads and invokes the vulnerable parsing routine — including Outlook's preview rendering — is potentially affected.

2.2 Affected Products

The following Microsoft products are confirmed affected:

- Microsoft Word 2016
- Microsoft 365 Apps for Enterprise (all channels)
- Microsoft Office LTSC 2021
- Microsoft Office LTSC 2024
- Microsoft Outlook (via shared DLL — Preview Pane vector)

2.3 Attack Scenarios

Security researchers and vendors have identified three primary exploitation scenarios:

- **Scenario A — Preview Pane (Zero-Click):**

An attacker delivers a weaponised .docx file via phishing email or a shared drive. The victim saves the file and navigates to that folder in Windows Explorer. If the Preview Pane is active (the default in many enterprise configurations), Word's rendering engine is invoked automatically — no double-click, no macro prompt, no Protected View warning — and the UAF condition fires.

- **Scenario B — Email Reading Pane (Outlook):**

A malicious .docx attachment is previewed directly within Outlook's Reading Pane without the recipient opening the attachment. The shared DLL is loaded by Outlook's rendering stack, triggering the same vulnerable code path.

- **Scenario C — Classic Document Open:**

A user is socially engineered into opening a malicious Word document. Exploitation occurs when Word processes the malformed file structure, even if macros are disabled. Protected View bypasses have been referenced in related research, though Microsoft has not confirmed an in-the-wild bypass at time of publication.

2.4 CVSS v3.1 Breakdown

Vector String: AV:L/AC:L/PR:N/UI:P/S:U/C:H/I:H/A:H → **Score: 8.4 (Critical)**

Metric	Value	Rationale
Attack Vector	Local (L)	Attacker needs a file on the local file system or accessible share
Attack Complexity	Low (L)	No special conditions; the UAF is reliably triggered
Privileges Required	None (N)	No account privileges needed on the target system
User Interaction	Required (P)	Victim must preview or browse to the file location
Scope	Unchanged (U)	Exploit stays within the Word/Outlook process boundary
Confidentiality	High (H)	Arbitrary code execution allows full data access
Integrity	High (H)	Arbitrary write capability post-exploitation
Availability	High (H)	Process crash / DoS also possible

3. Threat Landscape & Context

CVE-2026-40361 was released alongside three other Word RCEs (CVE-2026-40364, CVE-2026-40366, CVE-2026-40367) in the same Patch Tuesday cycle, an unusually dense cluster of Word memory-corruption bugs. Security researchers at Talos/Cisco and Tenable independently flagged CVE-2026-40361 and CVE-2026-40364 as the two most likely to be weaponised in near-term campaigns.

The Preview Pane attack vector echoes prior high-impact Office vulnerabilities — most notably CVE-2023-36884 and CVE-2021-40444 — both of which were rapidly adopted by nation-state and ransomware groups. Historically, Preview Pane vectors have shorter time-to-exploit windows because they lower the social engineering bar significantly: no 'Enable Editing', no 'Enable Macros', and no user decision is required beyond the victim navigating a folder.

At time of writing (May 13, 2026) there are no confirmed reports of in-the-wild exploitation. However, Microsoft's 'Exploitation More Likely' rating and the public patch (which can be diffed to reconstruct the vulnerable code path) means a reliable proof-of-concept is likely within days to weeks of patch release. Organisations should treat this as a high-urgency patching event.

4. Mitigation

Mitigations are listed in priority order. Patching is the only complete remediation; all other controls reduce attack surface but do not eliminate the vulnerability.

4.1 Apply the May 2026 Patch Tuesday Update (Primary)

This is the definitive fix. Deploy via:

- Windows Update / Microsoft Update — automatic for most end-user machines
- Microsoft Update Catalog — search for KB articles listed in the MSRC advisory for CVE-2026-40361
- WSUS / MECM / Intune — push the applicable update packages to managed endpoints
- Microsoft 365 Apps — use the Office Deployment Tool (ODT) or update channel controls to force an update pull

Verify deployment: Settings → Windows Update → View update history. Confirm the applicable KB is listed as 'Installed'.

4.2 Disable Preview Pane and Reading Pane (Interim Workaround)

Removes the zero-click attack vector in both Windows Explorer and Outlook. Deploy via Group Policy:

```
User Config → Administrative Templates → Windows Components  
→ File Explorer → Turn off the Preview Pane → Enabled
```

```
User Config → Administrative Templates → Microsoft Outlook → Outlook Options  
→ Web Content → Turn off Reading Pane → Enabled
```

This policy can be deployed immediately and does not require a reboot. It can be reversed once patching is confirmed complete.

4.3 Block Potentially Malicious Office File Types at Email Gateway

Configure your email security gateway (Defender for Office 365, Proofpoint, Mimecast, etc.) to quarantine or strip inbound .docx, .doc, .dotx, and .dotm attachments from external senders until patching is complete. Use policies that allow password-protected archives to be opened in a detonation sandbox before delivery.

4.4 Enable Attack Surface Reduction Rules (ASR)

Relevant ASR rules in Microsoft Defender for Endpoint:

- Block Office applications from creating executable content (GUID: 3B576869-A4EC-4529-8536-B80A7769E899)
- Block Office applications from injecting code into other processes (GUID: 75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84)
- Block execution of potentially obfuscated scripts (GUID: 5BEB7EFE-FD9A-4556-801D-275E5FFC04CC)

Note: ASR rules mitigate post-exploitation activity but do not block the UAF trigger itself. They should be used alongside — not instead of — patching and Preview Pane controls.

4.5 Principle of Least Privilege

Since the CVSSv3 score assumes code execution in the context of the logged-in user, limiting the privileges of user accounts reduces blast radius. Ensure end users do not run with local administrator rights. Where possible, deploy credential guard and restrict lateral movement paths from workstations.

5. Detection

The following detection approaches address both the exploitation trigger and post-exploitation activity. Defenders should implement detections in layers — file-level, process-level, and network-level — since no single signal is sufficient.

5.1 Endpoint Detection — Suspicious Child Process from Word/Outlook

A UAF exploit that achieves code execution will typically spawn a child process from WINWORD.EXE or OUTLOOK.EXE. Monitor for unexpected child processes using EDR telemetry:

```
Parent: WINWORD.EXE | OUTLOOK.EXE
Child:  cmd.exe | powershell.exe | wscript.exe | cscript.exe |
       mshta.exe | rundll32.exe | regsvr32.exe | certutil.exe |
       bitsadmin.exe | curl.exe | any unexpected network-capable binary
```

Flag and alert on any of the above parent → child relationships, especially if the child process has network activity or writes to startup locations.

5.2 Sigma Rule — Word/Outlook Spawning Shell

The following Sigma rule can be translated to most SIEM platforms (Splunk, Sentinel, Elastic, etc.):

```
title: Suspicious Child Process Spawned by Microsoft Word or Outlook
id: a3f7c821-9b4e-4d12-bce1-0f3d8a2e1234
status: experimental
description: >
  Detects shell or script interpreter processes spawned by Word or Outlook,
  consistent with exploitation of CVE-2026-40361 or similar Office RCE bugs.
references:
  - https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2026-40361
tags:
  - attack.execution
  - attack.t1203
  - attack.t1566.001
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    ParentImage|endswith:
      - '\WINWORD.EXE'
      - '\OUTLOOK.EXE'
    Image|endswith:
      - '\cmd.exe'
```

```

- '\powershell.exe'
- '\pwsh.exe'
- '\wscript.exe'
- '\cscript.exe'
- '\mshta.exe'
- '\rundll32.exe'
- '\regsvr32.exe'
- '\certutil.exe'
- '\bitsadmin.exe'
- '\curl.exe'

condition: selection
falsepositives:
- Legitimate macros that spawn shells (should be rare in well-managed environments)
- Some Office add-ins with scripting dependencies

level: high

```

5.3 Windows Event Log Indicators

Key Windows Event IDs to monitor in correlation with Office process activity:

Event ID	Log Source	Relevance
4688	Security	Process creation — correlate parent/child (requires ProcCreate auditing)
1	Sysmon	Process creation with full command-line capture — preferred over 4688
7	Sysmon	Image loaded — flag unexpected DLL loads within WINWORD.EXE
3	Sysmon	Network connection — Office process initiating outbound connections
11	Sysmon	File created — Office writing executables or scripts to disk
8103	MS-Office-Alerts	Protected View disabled or bypassed for a document

5.4 Microsoft Defender for Endpoint (MDE) Queries

Advanced Hunting query (KQL) for Microsoft Sentinel / MDE:

```

// CVE-2026-40361: Word/Outlook spawning shell processes
DeviceProcessEvents
| where InitiatingProcessFileName in~ ('WINWORD.EXE', 'OUTLOOK.EXE')
| where FileName in~ (
    'cmd.exe', 'powershell.exe', 'pwsh.exe', 'wscript.exe', 'cscript.exe',
    'mshta.exe', 'rundll32.exe', 'regsvr32.exe', 'certutil.exe', 'bitsadmin.exe'
)
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, FileName, ProcessCommandLine,
    InitiatingProcessCommandLine

```

```
| order by Timestamp desc
```

Network connection query:

```
// CVE-2026-40361: Office process making outbound network connections
DeviceNetworkEvents
| where InitiatingProcessFileName in~ ('WINWORD.EXE', 'OUTLOOK.EXE')
| where RemotePort in (80, 443, 445, 4444, 8080, 8443)
| summarize ConnectionCount=count(), Ports=make_set(RemotePort),
    RemoteIPs=make_set(RemoteIP) by DeviceName,
    InitiatingProcessFileName, bin(Timestamp, 1h)
| where ConnectionCount > 0
| order by Timestamp desc
```

5.5 YARA Rule — Malicious DOCX Structural Patterns

While a precise YARA rule requires access to exploit samples, the following rule targets structural anomalies common in weaponised Office documents exploiting UAF memory bugs:

```
rule CVE_2026_40361_Suspicious_DOCX {
  meta:
    description = "Suspicious DOCX structural patterns associated with CVE-2026-40361"
    author      = "Threat Intel Team"
    date       = "2026-05-13"
    reference   =
      "https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2026-40361"
    severity    = "high"
  strings:
    // Office Open XML marker
    $docx_magic = { 50 4B 03 04 }
    // Anomalous XML namespaces sometimes inserted by exploit builders
    $ns_anomaly1 = "http://schemas.openxmlformats.org/drawingml" wide ascii
    $ns_anomaly2 = "customXml" wide ascii
    // OLE stream references in OOXML (can indicate embedded exploit objects)
    $ole_ref     = "oleObject" wide ascii
    $embed_ref   = "embeddings" wide ascii
    // Common shellcode staging strings
    $shell_http  = /https?:\\/[0-9]{1,3}\\.[0-9]{1,3}/ wide ascii
  condition:
    $docx_magic at 0 and
    2 of ($ns_anomaly*, $ole_ref, $embed_ref) and
    $shell_http
}
```

Note: Update this rule with specific byte patterns from confirmed exploit samples as they become available. False positives are possible with legitimate documents containing embedded OLE objects.

6. Threat Hunting

Threat hunting assumes a breach-assumed posture and proactively searches for indicators of exploitation that may have bypassed automated detection. The following hunts should be run across at least 30–90 days of historical telemetry.

6.1 Hunt: Office Processes with Unusual Network Connections

Look for Word or Outlook establishing direct outbound network connections — unusual behaviour for standard document workflows:

```
// Splunk SPL equivalent
index=endpoint sourcetype=sysmon EventCode=3
| where process_name IN ("WINWORD.EXE", "OUTLOOK.EXE")
| where dest_port NOT IN (443, 80)
| stats count, values(dest_ip), values(dest_port) by host, process_name
| where count > 0
```

6.2 Hunt: File Writes from Office Processes

Post-exploitation typically involves staging a payload on disk. Hunt for Word/Outlook writing executables, scripts, or DLLs:

```
DeviceFileEvents
| where InitiatingProcessFileName in~ ('WINWORD.EXE', 'OUTLOOK.EXE')
| where FileName ends with '.exe'
    or FileName ends with '.dll'
    or FileName ends with '.ps1'
    or FileName ends with '.vbs'
    or FileName ends with '.bat'
    or FileName ends with '.hta'
| where FolderPath !contains @"\AppData\Local\Microsoft\Office\
| project Timestamp, DeviceName, AccountName, FileName, FolderPath,
    InitiatingProcessCommandLine
| order by Timestamp desc
```

6.3 Hunt: Preview Pane Activity Preceding Suspicious Processes

The Preview Pane attack vector involves Windows Explorer (explorer.exe) loading the Word COM rendering component. Hunt for explorer.exe loading Word-related DLLs followed by unusual process activity:

```
// Sysmon Event ID 7 (ImageLoad) – DLL loaded by explorer
index=endpoint sourcetype=sysmon EventCode=7
| where process_name="explorer.exe"
| where ImageLoaded LIKE "%MSWORD%"
    OR ImageLoaded LIKE "%wwlib%"
    OR ImageLoaded LIKE "%mso%"
| join host [search index=endpoint sourcetype=sysmon EventCode=1
| where process_name IN ("cmd.exe", "powershell.exe", "wscript.exe")]
| where abs(_time - _time2) < 30
```


| table _time, host, user, ImageLoaded, spawned_process

6.4 Hunt: Persistence Mechanisms Post-Exploitation

Successful exploitation is often followed by a persistence mechanism. Hunt for:

- New scheduled tasks created within 5 minutes of a Word/Outlook process anomaly
- Registry Run key writes originating from WINWORD.EXE, OUTLOOK.EXE, or their child processes
- New startup folder entries (User\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup)
- New services registered (Event ID 7045) within 30 minutes of the above process events

6.5 Hunt: Lateral Movement from Compromised Workstations

If exploitation results in a network-capable shell, look for SMB lateral movement, WMI/DCOM execution, or credential harvesting (LSASS access) originating from workstations that had Word or Outlook anomalies in the same time window.

7. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	Relevance to CVE-2026-40361
Initial Access	T1566.001 — Spearphishing Attachment	Malicious .docx delivered via phishing email
Execution	T1203 — Exploitation for Client Execution	UAF exploit triggers code execution on document preview
Execution	T1204.002 — User Execution: Malicious File	User browses folder or opens document
Defense Evasion	T1218 — System Binary Proxy Execution	Post-exploit shellcode may use LOLBins (regsvr32, rundll32)
Defense Evasion	T1055 — Process Injection	Potential injection from Word/Outlook into trusted processes
Persistence	T1547.001 — Registry Run Keys	Common post-exploit persistence mechanism
Persistence	T1053.005 — Scheduled Task/Job	Alternate persistence via Task Scheduler
Command & Control	T1071.001 — Web Protocols	C2 beacon over HTTP/HTTPS from compromised host
Credential Access	T1003.001 — LSASS Memory	Follow-on credential theft after initial access
Lateral Movement	T1021.002 — SMB/Windows Admin Shares	Lateral spread from compromised workstation

8. Recommended Actions Summary

Priority	Action	Owner	Timeline
P1 — Critical	Apply May 2026 Patch	IT / Patching Team	Immediately

	Tuesday Office/Word updates		
P1 — Critical	Disable Preview Pane & Reading Pane via GPO (workaround)	IT / Sysadmin	Within 24 hours
P1 — Critical	Block suspicious .docx attachments at email gateway	Email Security Team	Within 24 hours
P2 — High	Deploy Sigma/KQL detection rules to SIEM/EDR	SOC / Detection Eng.	Within 48 hours
P2 — High	Enable/verify ASR rules in MDE	Security Engineering	Within 48 hours
P2 — High	Run threat hunt queries across 30-day telemetry	Threat Hunt Team	Within 72 hours
P3 — Medium	Validate local admin rights are removed from end users	IT / IAM Team	Within 1 week
P3 — Medium	Update YARA rules with confirmed exploit samples	Threat Intel Team	As samples emerge
P3 — Medium	Confirm patch deployment via compliance reporting	Vuln. Management	Within 1 week

9. References

- [1] Microsoft Security Response Center. "CVE-2026-40361 Advisory." <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2026-40361>
- [2] Tenable. "Microsoft's May 2026 Patch Tuesday Addresses 118 CVEs." <https://www.tenable.com/blog/microsofts-may-2026-patch-tuesday-addresses-118-cves-cve-2026-41103>
- [3] Cisco Talos Intelligence. "Microsoft Patch Tuesday May 2026 — Prominent Vulnerabilities." <https://blog.talosintelligence.com/microsoft-patch-tuesday-may-2026/>
- [4] SC Media. "Patch Tuesday: No zero days among 137 Microsoft CVEs, 4 Word RCEs." <https://www.scworld.com/news/patch-tuesday-no-zero-days-among-137-microsoft-cves-4-word-rces>
- [5] Bleeping Computer. "Microsoft May 2026 Patch Tuesday fixes 120 flaws, no zero-days." <https://www.bleepingcomputer.com/news/microsoft/microsoft-may-2026-patch-tuesday-fixes-120-flaws-no-zero-days/>
- [6] Help Net Security. "Microsoft May 2026 Patch Tuesday: Many fixes, but no zero-days." <https://www.helpnetsecurity.com/2026/05/12/microsoft-may-2026-patch-tuesday/>
- [7] Security Boulevard. "Microsoft's May 2026 Patch Tuesday Addresses 118 CVEs." <https://securityboulevard.com/2026/05/microsofts-may-2026-patch-tuesday-addresses-118-cves-cve-2026-41103/>
- [8] CVEfeed.io. "CVE-2026-40361 Detail." <https://cvefeed.io/vuln/detail/CVE-2026-40361>
- [9] Dark Reading. "It's Patch Tuesday for Microsoft and Not a Zero-Day in Sight." <https://www.darkreading.com/application-security/patch-tuesday-microsoft-zero-day-sight>

[10] PDQ. "Patch Tuesday May 2026." <https://www.pdq.com/blog/patch-tuesday-may-2026/>

This report was compiled from publicly available threat intelligence sources. All detection rules are provided for defensive purposes. Update detection content as additional technical details and confirmed exploit samples become available.